

信息对抗技术实验报告

实验 8：使用 L0phtCrack 破解 Windows 口令实验（合规版）

姓名：张昌源

学号：2313177

实验日期：2026 年 5 月 17 日

目录

1 实验目的	2
2 实验环境	2
3 实验原理	3
3.1 Windows 本地账户与口令哈希	3
3.2 NTLM 哈希与口令审计	3
3.3 字典攻击与快速审计	4
4 实验准备	4
4.1 创建测试账户	4
4.2 准备弱口令字典	5
4.3 下载和安装 L0phtCrack	6
5 实验过程	7
5.1 导入本机 Windows 账户哈希	7
5.2 执行 Quick Password Audit	8
5.3 导入自定义弱口令字典	9
5.4 使用自定义字典完成补充审计	9
6 实验结果与分析	10
6.1 实验结果	10
6.2 结果分析	11
7 安全防护建议	11
8 实验思考题	12
8.1 为什么 L0phtCrack 需要管理员权限才能导入本地账户哈希?	12
8.2 字典攻击和暴力攻击有什么区别?	12
8.3 如何提升 Windows 口令安全性?	12
8.4 除了 L0phtCrack, 还有哪些常见口令审计工具?	12
9 实验总结	12

1 实验目的

本实验围绕 Windows 本地账户口令审计展开，主要目标如下：

- 1、掌握 L0phtCrack 7 的安装、导入本机账户哈希、快速审计和自定义字典审计的基本流程。
- 2、理解 Windows 本地账户、SAM 数据库、NTLM 哈希以及哈希匹配式口令破解的基本原理。
- 3、通过对个人 Windows 10 虚拟机中的测试账户进行审计，直观认识弱口令在哈希泄露或被导入审计工具后的安全风险。
- 4、明确口令审计工具的合法使用边界，树立“只对自己拥有权限的系统进行安全测试”的合规意识。

2 实验环境

本实验在 VMware Workstation 中新建 Windows 10 x64 虚拟机，并在虚拟机中安装 L0phtCrack 7.2.0 Win64 版本进行本地账户审计。实验过程中没有对宿主机、他人设备或公网目标进行测试。

表 1 实验环境配置

项目	配置说明
宿主环境	VMware Workstation 虚拟化环境
客户机系统	Windows 10 专业版，64 位操作系统，基于 x64 的处理器
客户机内存	4.00 GB
处理器	AMD Ryzen 5 5500U with Radeon Graphics，虚拟机分配 2 个处理器
审计工具	L0phtCrack 7.2.0 Win64 开源版本
测试账户	AdminTest、UserTest，以及系统中已有的 My_account 账户
辅助文件	自定义弱口令字典 weak_password.txt
合规范围	仅审计本人创建并控制的本地 Windows 虚拟机账户

Windows 系统信息如图1所示，可以看到该虚拟机为 64 位 Windows 10 专业版系统。



图 1 Windows 10 x64 虚拟机系统信息

3 实验原理

3.1 Windows 本地账户与口令哈希

Windows 本地用户账户是定义在本机设备上的安全主体，用于管理用户对本机资源的访问权限。微软文档说明，Windows 凭据默认会在本地计算机的 Security Accounts Manager (SAM) 数据库或域环境中的 Active Directory 中进行验证。对于本地用户账户，口令并不是以明文形式保存，而是保存为经过处理的哈希数据。微软关于口令技术的说明中也提到，在 workstation 和域成员机器上，本地用户账户的口令哈希保存在本地 SAM 数据库中。

因此，口令审计工具通常不是直接“读取明文密码”，而是先导入本机账户对应的哈希值，再将候选明文口令计算为相同类型的哈希，与已导入的哈希值进行比较。如果两者一致，就说明候选口令与原口令匹配，工具便可给出明文结果。

3.2 NTLM 哈希与口令审计

NTLM 是 Windows 环境中长期存在的一类认证机制。微软文档指出，NTLM 相关认证协议基于挑战—响应机制，用于证明用户知道账户对应的密码。在本实验中，L0phtCrack 从本地系统导入账户哈希后，对这些 NTLM 哈希进行口令审计。

需要注意的是，哈希机制可以避免系统直接保存明文密码，但并不意味着弱口令

绝对安全。一旦攻击者或审计人员能够合法地获得哈希并进行离线匹配，常见弱口令就可能被快速反推出明文。因此，口令本身的复杂度、长度和不可预测性仍然非常重要。

3.3 字典攻击与快速审计

字典攻击的核心思想是：将常见口令、弱口令、常见变体等写入字典文件，工具逐行读取候选口令，计算其哈希并与目标哈希进行匹配。与暴力枚举所有字符组合相比，字典攻击不追求穷尽所有可能，而是优先尝试现实中最容易出现的弱口令，因此对“123456”“12345678”“admin123”“admin@123”等常见口令非常有效。

L0phtCrack 7.2.0 已作为开源项目发布，并提供 Win64 版本下载入口。在本实验中，首先使用其 Quick Password Audit 进行快速审计，然后再导入自定义弱口令字典，对默认快速审计未命中的测试账户进行补充验证。

4 实验准备

4.1 创建测试账户

在 Windows 10 x64 虚拟机中，以管理员身份打开命令提示符，创建两个用于实验的本地测试账户。其中 AdminTest 设置为管理员组成员，UserTest 保持为普通测试用户。微软文档说明，`net user` 命令可用于添加、修改、删除和显示本地计算机或域中的用户账户。

执行命令如下：

Listing 1: 创建本地弱口令测试账户的命令

```
net user AdminTest 12345678 /add
net user UserTest admin@123 /add
net localgroup administrators AdminTest /add
net user
```

账户创建和查看结果如图2所示，可以看到 AdminTest 和 UserTest 均已出现在本地账户列表中。

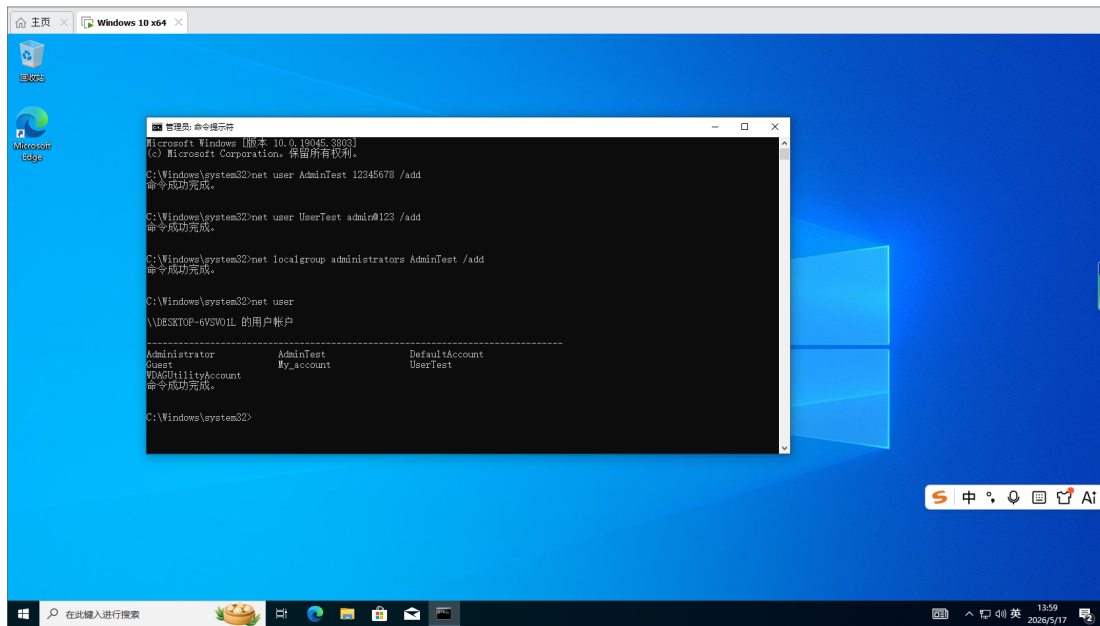


图 2 创建并查看弱口令测试账户

4.2 准备弱口令字典

为了验证自定义字典攻击的效果，在桌面新建 `weak_password.txt` 文件，并写入常见弱口令，每行一个候选口令。实验中使用的字典内容如下：

Listing 2: 实验用弱口令字典 `weak_password.txt`

```
123456
12345678
admin
admin123
admin@123
123456789
1234567890
111111
666666
888888
test
test123
user123
123abc
abc123
```

弱口令字典文件截图如图3所示，其中包含本实验设置的两个测试账户口令。

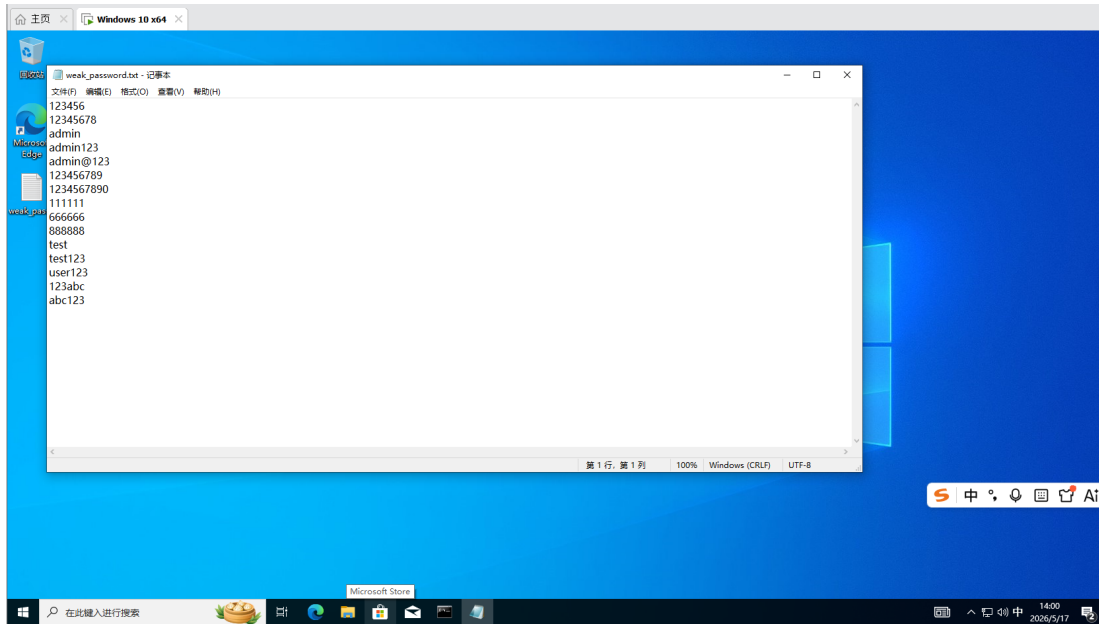


图 3 实验用弱口令字典文件

4.3 下载和安装 L0phtCrack

在虚拟机浏览器中访问 L0phtCrack 官方页面,下载开源 Win64 安装包 lc7setup_v7.2.0_Win64. 下载后的安装包如图4所示。

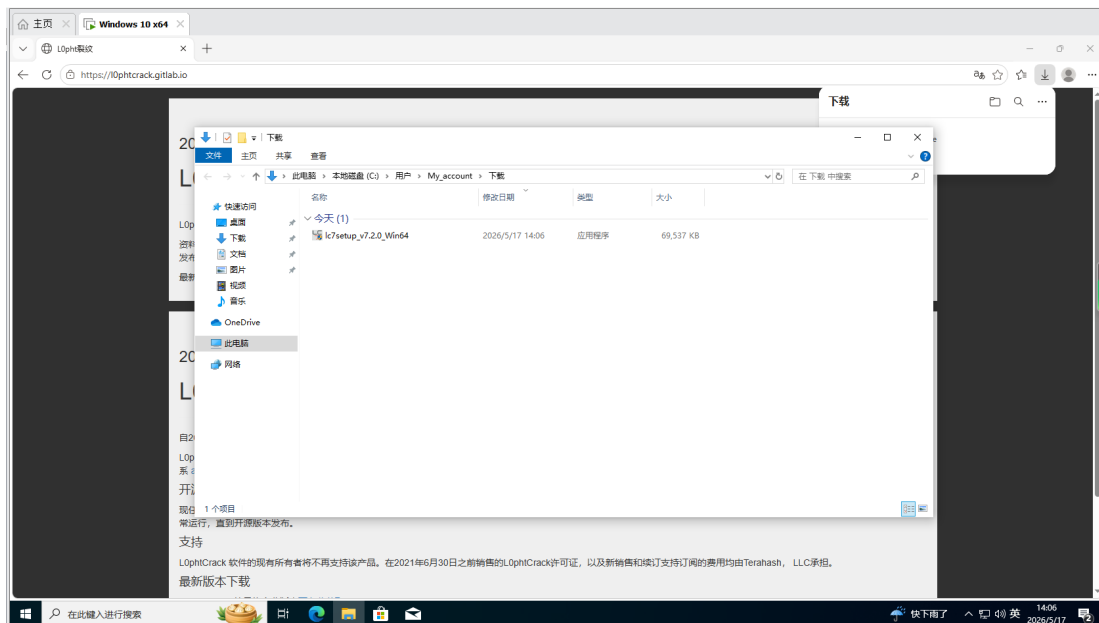


图 4 下载 L0phtCrack 7.2.0 Win64 安装包

安装完成后,以管理员身份运行 L0phtCrack。软件主界面和启动向导如图5所示。

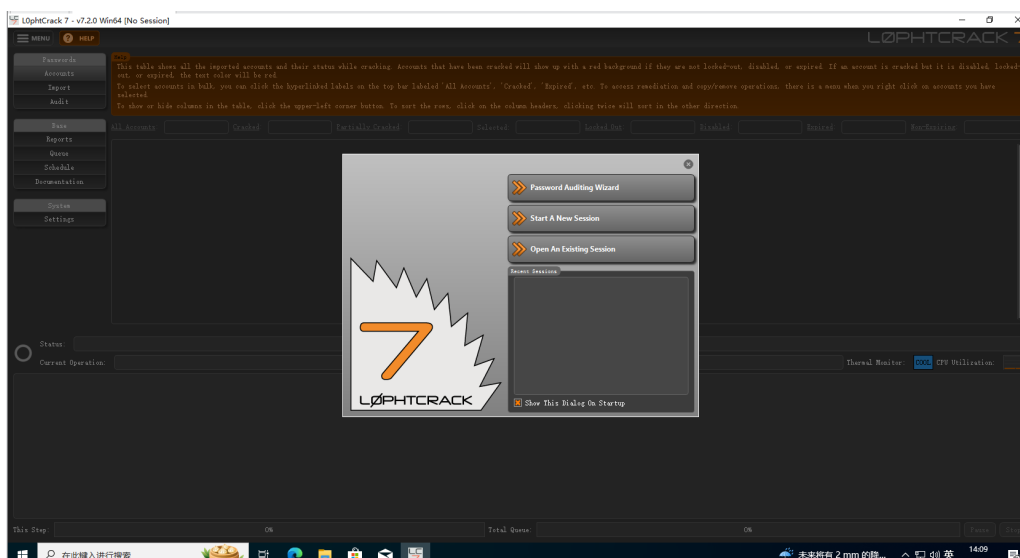


图 5 L0phtCrack 7 主界面和审计向导

5 实验过程

5.1 导入本机 Windows 账户哈希

进入 L0phtCrack 后，使用 Password Auditing Wizard 开始新的审计任务。目标系统类型选择 Windows，导入方式选择 The local machine，并使用当前登录用户凭据导入本机账户哈希。该过程只针对当前虚拟机，不涉及远程主机。

导入完成后，L0phtCrack 账户表中出现本机账户列表，包括 Administrator、AdminTest、My_account、UserTest 等账户，并显示对应的 NTLM Hash 和状态信息，如图6所示。

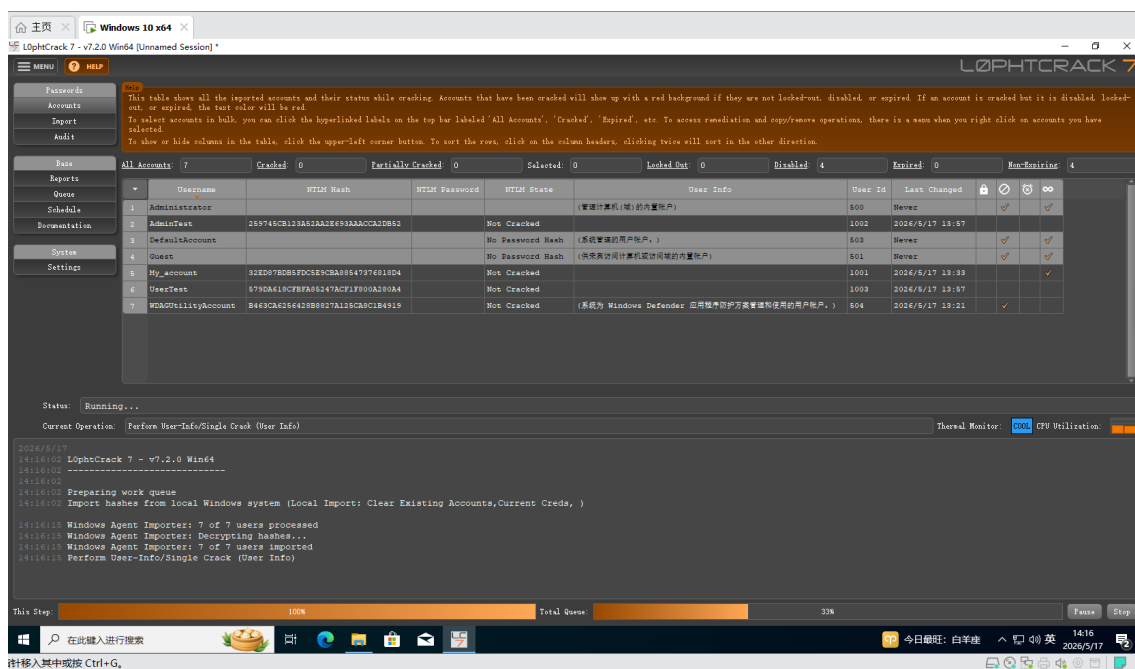


图 6 导入本机 Windows 账户哈希

5.2 执行 Quick Password Audit

导入本机账户哈希后，在审计向导中选择 Quick Password Audit，并保持默认报告选项和立即运行选项。该审计方式会使用默认的快速字典和常见变形规则尝试匹配弱口令。

Quick Password Audit 完成后，结果如图7所示。可以看到，AdminTest 被成功破解为 12345678，系统原有账户 My_account 被破解为 123456，但 UserTest 仍显示为 Not Cracked。

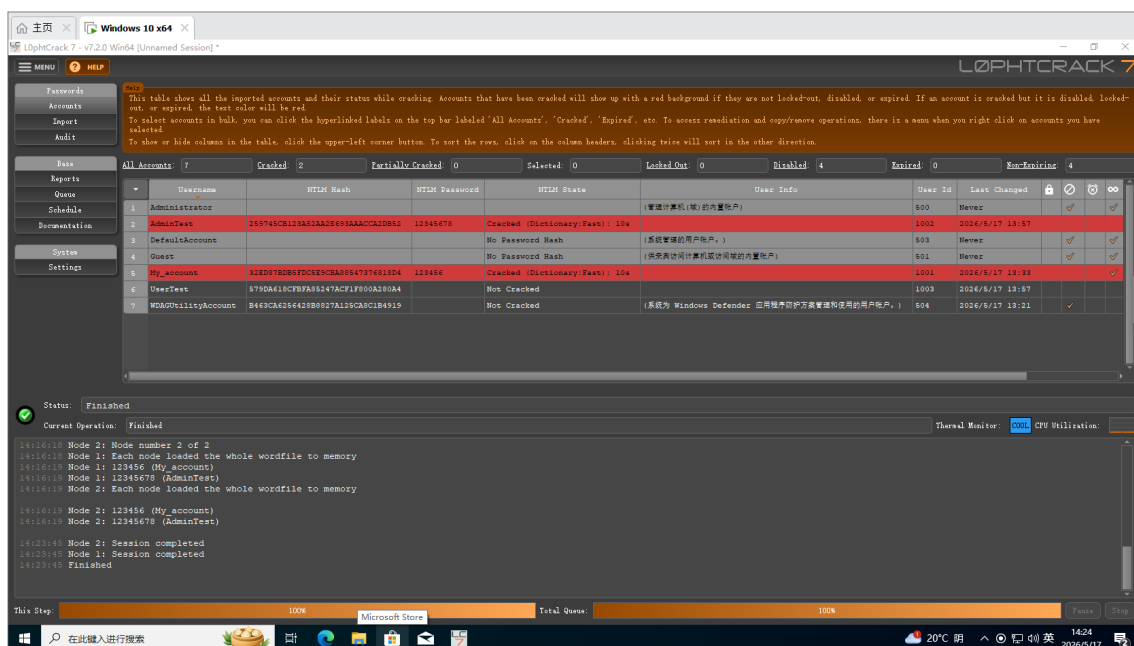


图 7 Quick Password Audit 快速审计结果

这一结果说明，默认快速审计能够命中部分非常常见的弱口令，但并不一定覆盖所有弱口令变体。例如 admin@123 这种包含符号的常见变体没有被默认快速审计命中，因此需要进一步使用自定义字典进行补充审计。

5.3 导入自定义弱口令字典

在 L0phtCrack 左侧进入 Audit 页面，选择 Dictionary 技术，创建 New Preset，并将 Wordlist 文件设置为桌面上的 weak_password.txt。自定义字典配置如图8所示。

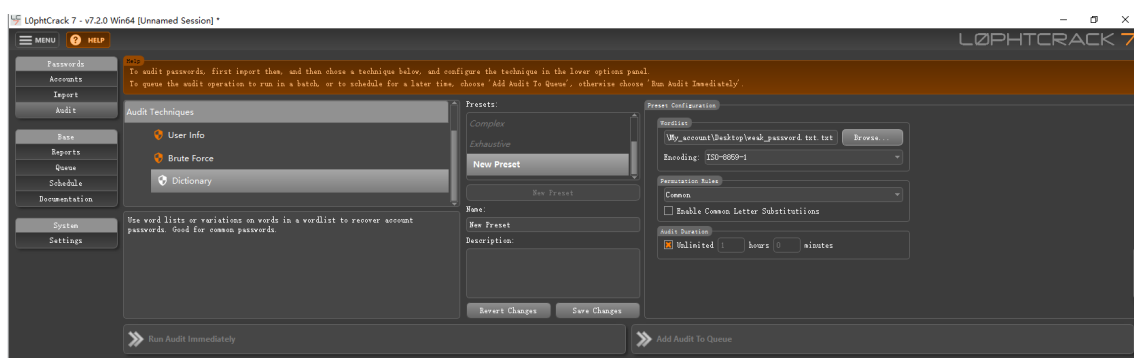


图 8 配置自定义弱口令字典

5.4 使用自定义字典完成补充审计

保存自定义字典预设后，立即运行 Dictionary 审计。由于 weak_password.txt 中包含 admin@123，UserTest 很快被成功破解。最终结果如图9所示。

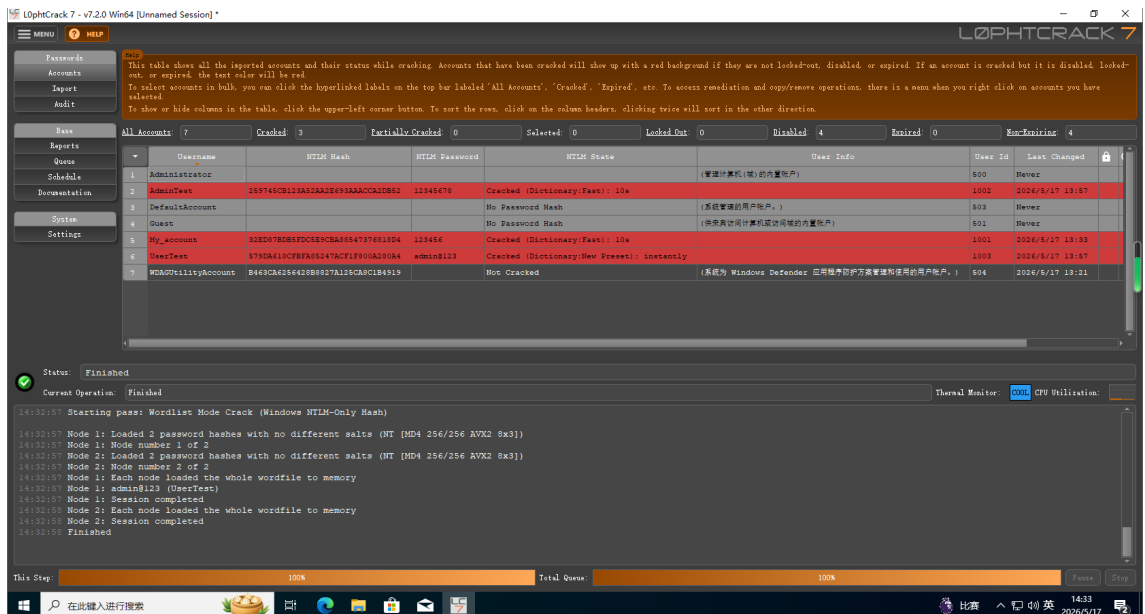


图 9 使用自定义弱口令字典完成最终破解

最终界面中可以看到 Cracked 数量为 3，AdminTest、UserTest 和 My_account 均已被成功破解。日志中也显示自定义字典模式加载后，UserTest 对应口令 admin@123 被命中。

6 实验结果与分析

6.1 实验结果

本实验的最终破解结果如表2所示。

表 2 口令审计结果汇总

用户名	设置/实际口令	审计方式	审计结果
AdminTest	12345678	Quick Password Audit	成功破解，耗时约 10 秒。
UserTest	admin@123	自定义 weak_password.txt 字典	成功破解，几乎瞬间命中。
My_account	123456	Quick Password Audit	成功破解，说明系统原账户也使用了弱口令。

6.2 结果分析

第一, 12345678 这类连续数字口令极易被默认快速审计命中。L0phtCrack 在 Quick Password Audit 阶段就成功破解 AdminTest, 说明常见数字组合属于高风险弱口令。

第二, admin@123 虽然包含特殊符号, 但仍然是典型的管理员口令变体。默认快速审计没有命中它, 但只要自定义字典中包含该候选项, 就能立即完成匹配。这说明“字母 + 符号 + 数字”并不必然等于强口令, 关键还要看口令是否常见、是否可预测。

第三, 字典攻击的效果高度依赖字典质量。默认字典适合快速覆盖最常见口令, 自定义字典则可结合实验目标或组织环境特点补充候选词。本实验中, 自定义字典只有十余个候选口令, 但由于准确包含目标口令, 因此效率非常高。

第四, 哈希机制本身并不保存明文口令, 但弱口令对应的哈希仍然容易被反向匹配。换言之, 口令哈希不是弱口令的“免死金牌”。如果口令本身简单或常见, 一旦哈希被合法审计工具或攻击者获得, 就存在被快速破解的风险。

7 安全防护建议

结合本次实验结果, Windows 本地账户口令安全可以从以下几个方面加强:

- 1、避免使用 123456、12345678、admin123、admin@123 等常见弱口令和常见变体。
- 2、设置更长、更不可预测的口令, 建议使用 12 位以上长度, 并混合大小写字母、数字和符号。
- 3、尽量使用口令短语或密码管理器生成的随机口令, 减少人为可预测规律。
- 4、对管理员账户启用更严格的口令策略, 并定期检查是否存在弱口令账户。
- 5、限制本地管理员权限, 避免普通用户拥有不必要的高权限。
- 6、实验或测试结束后及时删除测试账户、测试字典和审计输出文件, 防止遗留敏感信息。

实验结束后, 可使用如下命令删除测试账户:

Listing 3: 实验结束后的测试账户清理命令

```
net user AdminTest /delete  
net user UserTest /delete
```

8 实验思考题

8.1 为什么 L0phtCrack 需要管理员权限才能导入本地账户哈希？

Windows 本地账户哈希属于系统敏感凭据信息,普通用户不能直接读取。L0phtCrack 在本机审计时需要访问本地账户数据库相关信息,因此必须以管理员身份运行。这样可以避免普通用户随意读取和审计系统账户哈希,也体现了 Windows 对凭据数据的权限保护。

8.2 字典攻击和暴力攻击有什么区别？

字典攻击使用已有候选口令列表进行匹配,优点是速度快、针对常见弱口令效果好,缺点是无法命中不在字典中的复杂口令。暴力攻击则尝试枚举指定字符集和长度范围内的所有组合,理论覆盖面更广,但随着口令长度和字符集增加,计算量会急剧上升。因此,本实验选择字典攻击,更符合弱口令验证场景。

8.3 如何提升 Windows 口令安全性？

提升口令安全性的关键是减少可预测性。用户应避免使用生日、姓名、常见词、简单数字序列和管理员常见变体,设置足够长且随机的口令。同时,还可以启用账户锁定策略、限制本地管理员数量、定期审计弱口令,并对重要账户启用多因素认证。

8.4 除了 L0phtCrack, 还有哪些常见口令审计工具？

常见工具还包括 John the Ripper、Hashcat 等。它们都可以用于合法的口令安全测试,但具体侧重点不同: L0phtCrack 面向 Windows 口令审计场景较直观; Hashcat 更强调 GPU 加速和大规模哈希计算; John the Ripper 则在多平台口令审计中应用广泛。无论使用哪种工具,都必须限定在合法授权范围内。

9 实验总结

本次实验在个人 Windows 10 x64 虚拟机中完成,先后进行了测试账户创建、弱口令字典准备、L0phtCrack 安装、本机账户哈希导入、快速审计和自定义字典审计。实验最终成功破解 AdminTest 的 12345678、UserTest 的 admin@123 以及系统原有账户 My_account 的 123456,达到了实验要求。

实验结果表明,Windows 系统虽然不会以明文形式保存口令,但弱口令在哈希审计场景下仍然非常脆弱。默认快速审计能够命中典型弱口令,自定义字典则可以针对特定弱口令变体进行补充验证。通过本实验可以更加直观地理解:口令安全的根本不只在于“系统是否保存明文”,更在于用户口令本身是否足够复杂、足够不可预测。

同时，本实验也进一步强化了安全工具使用的合规意识。L0phtCrack 等口令审计工具只能用于本人拥有权限的系统、实验虚拟机或经过明确授权的安全测试环境，不能用于未经授权的设备或账户。实验完成后，应及时删除测试账户和相关文件，避免留下安全隐患。